

EVALUACIÓN DETALLADA · 9 DE AGOSTO DE 2026

Evaluación de Superficie de Ataque

Example

example.com

90

PUNTAJE DE RIESGO / 100

Crítico

01 · RESUMEN EJECUTIVO

Resumen Ejecutivo

Evaluación de superficie del dominio **example.com** mediante reconocimiento pasivo e inspección de los servicios expuestos públicamente en internet. No se realizaron pruebas de intrusión activa.

1 CRÍTICOS	2 ALTOS	1 MEDIOS	1 BAJOS
---------------	------------	-------------	------------

Se identificaron debilidades en la configuración de correo del dominio **@example.com** que permiten suplantar el remitente. Se recomienda implementar DMARC con política **p=reject** como prioridad inmediata.

SEGURIDAD DE CORREO ELECTRÓNICO

SPF SPF configurado correctamente con -all ▲ Bajo <pre>v=spf1 -all</pre>	DMARC DMARC presente pero con p=none (sin efecto real) ▲ Alto — correos fraudulentos no son rechazados automáticamente <pre>v=DMARC1; p=none</pre>
ENTREGABILIDAD DE CORREO El correo saliente del dominio puede ser rechazado o filtrado ▲ Crítico — correo saliente rechazado o filtrado	MTA-STS MTA-STS no configurado — TLS no forzado en correos entrantes ▲ Medio — sin garantía de cifrado en tránsito

Impacto operacional de la configuración de correo. Sin SPF y DMARC correctamente configurados, los servidores de destino pueden rechazar o filtrar el correo saliente de **@example.com**, y un tercero puede enviar correo suplantando el dominio sin que el receptor disponga de una señal técnica para distinguirlo del legítimo.

Este informe fue generado mediante reconocimiento pasivo e inspección de servicios expuestos públicamente. No se realizaron pruebas de explotación activa ni acceso no autorizado a sistemas. Los hallazgos representan riesgos potenciales identificados desde internet, sin autenticación.

02 · ESCENARIOS DE RIESGO

Escenarios de Riesgo

Los siguientes escenarios describen cómo los hallazgos técnicos identificados en **example.com** podrían ser aprovechados si no se remedian.

Suplantación de identidad por correo (BEC)

ALTO

El dominio @example.com tiene DMARC en p=none: la política no instruye rechazar ni poner en cuarentena. Sin una política DMARC que instruya al receptor, un tercero puede enviar correo con el dominio example.com en el remitente y los servidores de destino no tienen una señal para rechazarlo.

Email spoofing → instrucción falsa → acción del destinatario

IMPACTO OPERACIONAL

Correo fraudulento con remitente aparentemente legítimo puede llegar a destinatarios internos y externos. Sin registros DMARC agregados, la organización no tiene visibilidad de los envíos que suplantán su dominio.

IMPACTO REPUTACIONAL

Los destinatarios no pueden distinguir un correo suplantado de uno emitido por Example. La confianza en el canal de correo del dominio se degrada para todos sus interlocutores.

Plan de Remediación Priorizado

SEVERIDAD	ACCIÓN TÉCNICA	ACTIVO	ESFUERZO
ALTO	Endurecer DMARC de p=none a p=reject	example.com	BAJO
Esfuerzo agregado			BAJO
El esfuerzo indicado es una estimacion de trabajo tecnico de configuracion; no incluye validacion ni monitoreo posterior.			

Tabla de Hallazgos

ID	SEVERIDAD	HALLAZGO	CATEGORÍA	CVSS	RIESGO DE CONTINUIDAD
VULN-003	CRÍTICA	Generic CVE example.com	Sin categoría	9.0-10.0	MEDIO
VULN-001	ALTA	DMARC sin enforcement (p=none) example.com	Seguridad de correo electrónico	7.0-8.9	BAJO
VULN-004	ALTA	Exposed panel example.com	Sin categoría	7.0-8.9	MEDIO
VULN-005	MEDIA	Cabeceras de seguridad HTTP ausentes example.com	Sin categoría	4.0-6.9	MEDIO
VULN-002	BAJA	Cifrado SMTP forzado (MTA-STX) no configurado example.com	Seguridad de correo electrónico	0.1-3.9	MEDIO
GRP-006	INFORMATIVA	Sin categoría (1 hallazgos) example.com	Sin categoría	0.0	BAJO

05 · DETALLE DE HALLAZGOS

Detalle de Hallazgos

VULN-003 Generic CVE		CRÍTICA
HOST AFECTADO	CATEGORÍA	
example.com	Sin categoría	
CVSS		
9.0–10.0		
¿QUÉ SIGNIFICA ESTE HALLAZGO?		
Sin descripción disponible.		
RECOMENDACIÓN		
Revisar configuración según guías de seguridad del fabricante y OWASP.		

VULN-001 DMARC sin enforcement (p=none)		ALTA
HOST AFECTADO	CATEGORÍA	
example.com	Seguridad de correo electrónico	
CVSS		
7.0–8.9		
¿QUÉ SIGNIFICA ESTE HALLAZGO?		
El dominio tiene DMARC pero con política p=none, que solo monitorea sin rechazar correos fraudulentos. Cualquier servidor puede suplantar @example.com y los destinatarios recibirán el correo normalmente. Registro actual: v=DMARC1; p=none		
RECOMENDACIÓN		
Escalar la política DMARC progresivamente: 1) p=quarantine para mover sospechosos a spam, 2) p=reject para bloquear definitivamente. Agregar rua=mailto:dmarc@example.com para recibir reportes.		
REFERENCIAS		
https://dmarc.org/overview/		
https://dmarcguide.globalcyberalliance.org/		

VULN-004

Exposed panel

ALTA

HOST AFECTADO

example.com

CATEGORÍA

Sin categoría

CVSS

7.0–8.9

¿QUÉ SIGNIFICA ESTE HALLAZGO?

Sin descripción disponible.

RECOMENDACIÓN

Revisar configuración según guías de seguridad del fabricante y OWASP.

VULN-005

Cabeceras de seguridad HTTP ausentes

MEDIA

HOST AFECTADO

example.com

CATEGORÍA

Sin categoría

CVSS

4.0–6.9

¿QUÉ SIGNIFICA ESTE HALLAZGO?

Sin descripción disponible.

RECOMENDACIÓN

Revisar configuración según guías de seguridad del fabricante y OWASP.

Marco de Cumplimiento Aplicable

OWASP Top 10 (2021)

Categorías de riesgo de seguridad en aplicaciones web mantenidas por la OWASP Foundation. Se usan aquí como marco de referencia técnico para clasificar los hallazgos del reconocimiento pasivo.

<https://owasp.org/Top10/>

CONTROL	HALLAZGOS
A02:2021 — Cryptographic Failures Seguridad de correo electrónico	1
A07:2021 — Identification and Authentication Failures La ausencia de DMARC permite suplantar la identidad del dominio en el canal de correo. Seguridad de correo electrónico	1
Sin control asociado en este framework El hallazgo no encaja en ningun tag mapeado. Revisar y, si aplica, agregar el tag al archivo del framework. Sin categoría	4

ALCANCE Y LIMITACIONES

Análisis realizado exclusivamente mediante técnicas OSINT y reconocimiento pasivo de superficie, sin acceso a sistemas internos, bases de datos ni código fuente. Los hallazgos reflejan el estado de la infraestructura pública en la fecha de análisis. El mapeo a controles es orientativo y no constituye una certificación de cumplimiento.



La seguridad no es un estado. Es un proceso.

Los hallazgos de este informe reflejan la superficie expuesta en la fecha de análisis. La remediación de un hallazgo no elimina la necesidad de reevaluar: la superficie cambia con cada despliegue, cada servicio nuevo y cada cambio de DNS.

PRÓXIMOS PASOS

- Revisión de hallazgos críticos
- Plan de remediación priorizado
- Reevaluación periódica de superficie

ALCANCE

- Reconocimiento pasivo
- Sin pruebas activas
- Sin acceso a sistemas internos